



Section 26 / 30

Linux Security

All computer systems have an inherent risk of intrusion. Some present more of a risk than others, such as an internet-facing web server hosting multiple complex web applications. Linux systems are also less prone to viruses that affect Windows operating systems and do not present as large an attack surface as Active Directory domain-joined hosts. Regardless, it is essential to have certain fundamentals in place to secure any Linux system.

One of the Linux operating systems' most important security measures is keeping the OS and installed packages up to date. This can be achieved with a command such as:

```
athane@htb[/htb]$ apt update && apt dist-upgrade
```

shellsession

If firewall rules are not appropriately set at the network level, we can use the Linux firewall and/or `iptables` to restrict traffic into/out of the host.

If SSH is open on the server, the configuration should be set up to disallow password login and disallow the root user from logging in via SSH. It is also important to avoid logging into and

administering the system as the root user whenever possible and adequately managing access control. Users' access should be determined based on the principle of least privilege. For example, if a user needs to run a command as root, then that command should be specified in the `sudoers` configuration instead of giving them full sudo rights. Another common protection mechanism that can be used is `fail2ban`. This tool counts the number of failed login attempts, and if a user has reached the maximum number, the host that tried to connect will be handled as configured.

It is also important to periodically audit the system to ensure that issues do not exist that could facilitate privilege escalation, such as an out-of-date kernel, user permission issues, world-writable files, and misconfigured cron jobs, or misconfigured services. Many administrators forget about the possibility that some kernel versions have to be updated manually.

An option for further locking down Linux systems is `Security-Enhanced Linux` (`SELinux`) or `AppArmor`. This is a kernel security module that can be used for security access control policies. In SELinux, every process, file, directory, and system object is given a label. Policy rules are created to control access between these labeled processes and objects and are enforced by the kernel. This means that access can be set up to control which users and applications can access which resources. SELinux provides very granular access controls, such as specifying who can append to a file or move it.

Besides, there are different applications and services such as `Snort`, `chkrootkit`, `rkhunter`, `Lynis`, and others that can contribute to Linux's security. In addition, some security settings should be made, such as:

- Removing or disabling all unnecessary services and software

- Removing all services that rely on unencrypted authentication mechanisms
- Ensure NTP is enabled and Syslog is running
- Ensure that each user has its own account
- Enforce the use of strong passwords
- Set up password aging and restrict the use of previous passwords
- Locking user accounts after login failures
- Disable all unwanted SUID/SGID binaries

This list is incomplete, as safety is not a product but a process. This means that specific steps must always be taken to protect the systems better, and it depends on the administrators how well they know their operating systems. The better the administrators are familiar with the system, and the more they are trained, the better and more secure their security precautions and security measures will be.

TCP Wrappers

TCP wrapper is a security mechanism used in Linux systems that allows the system administrator to control which services are allowed access to the system. It works by restricting access to certain services based on the hostname or IP address of the user requesting access. When a client attempts to connect to a service the system will first consult the rules defined in the TCP wrappers configuration files to determine the IP address of the client. If the IP address matches the criteria specified in the configuration files, the system will then grant the client access to the service. However, if the criteria are not met, the connection will be denied, providing an additional layer of security for the service. TCP wrappers use the following configuration files:

- `/etc/hosts.allow`

- `/etc/hosts.deny`

In short, the `/etc/hosts.allow` file specifies which services and hosts are allowed access to the system, whereas the `/etc/hosts.deny` file specifies which services and hosts are not allowed access. These files can be configured by adding specific rules to the files.

`/etc/hosts.allow`

```
shellsession
athane@htb[/htb]$ cat /etc/hosts.allow

# Allow access to SSH from the local network
sshd : 10.129.14.0/24

# Allow access to FTP from a specific host
ftpd : 10.129.14.10

# Allow access to Telnet from any host in the inlanefreight.local domain
telnetd : .inlanefreight.local
```

`/etc/hosts.deny`

```
shellsession
athane@htb[/htb]$ cat /etc/hosts.deny

# Deny access to all services from any host in the inlanefreight.com domain
ALL : .inlanefreight.com

# Deny access to SSH from a specific host
```

```
sshd : 10.129.22.22
```

```
# Deny access to FTP from hosts with IP addresses in the range of 10.129.22.0 to  
10.129.22.255
```

```
ftpd : 10.129.22.0/24
```

It is important to remember that the order of the rules in the files is important. The first rule that matches the requested service and host is the one that will be applied. It is also important to note that TCP wrappers are not a replacement for a firewall, as they are limited by the fact that they can only control access to services and not to ports.



26 / 30 Sections



Mark Complete & Next